TEK-UP — Formation Cybersécurité
Année universitaire 2026–2027

Conception et mise en œuvre d'une solution de gestion des accès privilégiés (PAM)

Ayachi Yassine et Elheni Cyrine
5-SSIR-A

Table des matières

Liste des acronymes **3**

1 Introduction générale **4**
1.1 Contexte et importance des comptes privilégiés 4
1.2 Contexte et justification du projet 4
1.3 Problématique 4
1.4 Objectif général et objectifs spécifiques 4
1.5 Démarche méthodologique 5
1.6 Périmètre et limites 5
1.7 Organisation du rapport 5

2 Étude de l'existant et étude comparative **6**
2.1 État de l'existant 6
2.2 Concepts et catégories de solutions 6
2.3 Étude comparative des solutions 7
2.3.1 Fiches synthétiques 7
2.3.2 Tableau comparatif 7
2.4 Justification du choix des composants 8
2.5 Synthèse de l'étude de l'existant 9

3 Analyse des besoins et cahier des charges **10**
3.1 Problématique détaillée 10
3.2 Objectifs mesurables 10
3.3 Acteurs et rôles 10
3.4 Besoins fonctionnels 10
3.5 Besoins non fonctionnels 11
3.6 Contraintes 12
3.7 Périmètre et hors périmètre 12
3.8 Critères d'acceptation 12

4 Conception préliminaire de la solution **13**
4.1 État de l'environnement et hypothèses de déploiement 13
4.2 Architecture logique 13

4.3 Plan d'adressage . . . 14
4.4 Pare-feu et filtrage des flux réseau . . . 14
4.4.1 Rôle dans la défense en profondeur . . . 14
4.4.2 Isolation, pare-feu hôte et pare-feu centralisé . . . 15
4.4.3 Étude des options . . . 15
4.4.4 Segmentation, moindre privilège et anti-contournement . . . 15
4.5 Matrice des flux réseau (proposée) . . . 16
4.6 Matrice initiale des rôles et permissions (proposée) . . . 17
4.7 Analyse des menaces liées au filtrage . . . 17
4.8 Stratégie de collecte des journaux . . . 18
4.9 Plan de tests . . . 18
4.9.1 Tests T01 à T12 (synthèse) . . . 18
4.9.2 Tests de pare-feu T13 à T18 . . . 19
4.10 Indicateurs prévus . . . 20

5 Mise en œuvre et résultats observés 21
5.1 Statut de ce chapitre et méthode . . . 21
5.2 Environnement réalisé . . . 21
5.2.1 Machines et adressage . . . 21
5.2.2 Architecture réalisée . . . 21
5.3 Active Directory et DNS . . . 22
5.4 Déploiement de Teleport . . . 22
5.5 Services Docker sur PAM-TARGET01 . . . 23
5.6 Rôles et utilisateurs implémentés . . . 23
5.7 Tests d'autorisation observés . . . 24
5.8 Preuves d'audit . . . 24
5.9 Pare-feu : règles appliquées et tests . . . 25
5.9.1 Règles . . . 25
5.9.2 Résultats . . . 25
5.9.3 Observations à signaler . . . 25
5.10 Difficultés rencontrées et corrections . . . 26
5.11 Limites et compromis assumés . . . 26
5.12 Travaux restants . . . 26

Bibliographie et webographie 28

Liste des acronymes

AD DS	Active Directory Domain Services
BF / BNF	Besoin fonctionnel / non fonctionnel
DNS	Domain Name System
CA	Autorité de certification
IAM	Gestion des identités et des accès
IdP	Fournisseur d'identité
KPI	Indicateur de performance
LDAP	Lightweight Directory Access Protocol
NTP	Network Time Protocol
MFA	Authentification multifacteur
MTTA	Mean Time to Acknowledge
MTTD	Mean Time to Detect
TOTP	Mot de passe à usage unique basé sur le temps
PAM	Gestion des accès privilégiés
RBAC	Contrôle d'accès fondé sur les rôles
SIEM	Gestion des événements de sécurité
SSO	Authentification unique
XDR	Détection et réponse étendues

Chapitre 1

Introduction générale

1.1 Contexte et importance des comptes privilégiés

Les infrastructures d'entreprise reposent sur des serveurs, des applications, des bases de données et des services interconnectés. Leur administration exige des privilèges élevés (comptes `root`, administrateurs de domaine, accès aux moteurs de conteneurs). Lorsque ces privilèges sont permanents, partagés, excessifs ou peu surveillés, la compromission d'un seul compte peut permettre de modifier des configurations, d'accéder à des données sensibles, d'installer des logiciels malveillants ou d'interrompre des services critiques.

Le risque est renforcé par la conteneurisation : selon la documentation de Docker, seuls des utilisateurs de confiance devraient pouvoir contrôler le démon Docker, qui requiert des privilèges `root` sauf en mode rootless [8]. L'accès au moteur Docker constitue donc lui-même un accès privilégié.

1.2 Contexte et justification du projet

Le projet consiste à construire un laboratoire représentatif d'une petite infrastructure d'entreprise pour étudier le contrôle des accès privilégiés, le moindre privilège, la traçabilité des opérations d'administration et la détection de comportements suspects. L'encadrant a précisé que l'architecture doit ressembler à un environnement d'entreprise et **inclure un pare-feu** ; les options de filtrage sont étudiées dans ce rapport, mais leur mise en œuvre reste à valider selon la topologie retenue.

1.3 Problématique

Comment centraliser et contrôler les accès privilégiés aux ressources d'une infrastructure, limiter l'administration non autorisée, assurer la traçabilité des opérations sensibles, et exploiter les événements de sécurité pour détecter et investiguer les tentatives de contournement, y compris les contournements par le réseau ?

1.4 Objectif général et objectifs spécifiques

Objectif général. Concevoir une architecture de laboratoire permettant d'étudier le contrôle des accès privilégiés à un serveur Linux et aux services qu'il héberge. Le déploiement et l'évaluation seront réalisés dans la mesure où les ressources, les licences et la topologie retenue le permettent.

Objectifs spécifiques :

- étudier les solutions IAM, PAM, SIEM et de filtrage réseau ;

- déployer Active Directory (AD DS) et DNS comme référentiel d'identités ;
- mettre en place une solution PAM (Teleport Community Edition envisagée) ;
- héberger Nginx, une application Web/API et PostgreSQL dans des conteneurs Docker sur un serveur Linux ;
- définir des rôles et appliquer le moindre privilège ;
- restreindre les chemins d'accès directs contournant le PAM, par des règles de pare-feu notamment ;
- collecter et analyser les journaux avec Wazuh ;
- exécuter des tests d'autorisation, de refus, de traçabilité, de détection, de contournement et de filtrage ;
- calculer les indicateurs uniquement pour les tests effectivement exécutés et documentés.

1.5 Démarche méthodologique

(1) étude de l'existant et des solutions à partir de la documentation officielle ; (2) analyse des besoins et des contraintes ; (3) conception préliminaire (architecture, flux, rôles, journalisation) ; (4) déploiement progressif ; (5) exécution des scénarios de test et collecte de preuves ; (6) calcul des indicateurs et rédaction des conclusions. **À la date de ce document, la phase 4 est partiellement réalisée et la phase 5 partiellement exécutée (chapitre 5) ; la phase 6 (indicateurs finaux) n'est pas réalisée.** Les affirmations sont classées en trois catégories : faits sourcés (avec référence), interprétations, décisions de conception.

1.6 Périmètre et limites

Le périmètre envisagé est un laboratoire local, sur un poste d'environ 16 Go de RAM. Le réseau Host-only, les composants retenus et leur emplacement restent à confirmer. Le cloud public, la haute disponibilité et le SSO Keycloak–Teleport CE ne sont pas prévus dans le périmètre initial (voir section 3.7). Une fonction documentée par un éditeur ne sera considérée comme démontrée qu'après vérification ou test dans l'environnement retenu.

1.7 Organisation du rapport

Le chapitre 2 présente l'existant et compare les solutions ; le chapitre 3 formalise les besoins ; le chapitre 4 propose la conception préliminaire, dont la sous-section « Pare-feu et filtrage des flux réseau », la matrice des flux, l'analyse des menaces et le plan de tests ; le chapitre 5 présente la mise en œuvre réalisée et les résultats effectivement observés. La bibliographie et la liste des décisions ouvertes terminent le document.

Chapitre 2

Étude de l'existant et étude comparative

2.1 État de l'existant

- **Administration par SSH.** L'accès direct aux serveurs par SSH, souvent par clés statiques ou mots de passe, laisse peu de contrôle centralisé et une traçabilité limitée aux journaux locaux.
- **Comptes privilégiés locaux et administrateurs.** Comptes partagés ou permanents : imputabilité faible, rotation rare, privilèges excédant le besoin.
- **Annuaire.** Un annuaire (Active Directory) centralise utilisateurs et groupes, mais n'applique pas par lui-même le moindre privilège sur les serveurs Linux.
- **Docker.** L'accès au démon équivaut à un accès privilégié sur l'hôte [8]. Par ailleurs, les ports publiés par Docker ne passent pas par les règles `INPUT` d'un pare-feu hôte comme `ufw` : Docker fournit la chaîne `DOCKER-USER` pour ce filtrage [9, 10].
- **Journalisation et supervision.** Journaux dispersés, non corrélés, rarement exploités sans SIEM.

Limites : privilèges permanents, contournements possibles (accès direct), journaux incomplets ou non centralisés, absence de filtrage réseau explicite entre les composants.

2.2 Concepts et catégories de solutions

Notion	Définition retenue dans ce rapport
IAM	Gestion des identités et des droits associés (création, groupes, authentification, cycle de vie).
IdP	Service qui authentifie les utilisateurs et émet des assertions/jetons aux applications (ex. Keycloak).
PAM	Contrôle, limitation et audit des accès privilégiés aux ressources (serveurs, bases, conteneurs) : accès à la demande, durée limitée, enregistrement de sessions.
RBAC	Attribution des droits à des rôles, eux-mêmes attribués aux utilisateurs.
MFA	Authentification combinant au moins deux facteurs indépendants.
SIEM/XDR	Collecte, normalisation, corrélation et alerte sur les événements de sécurité.
Pare-feu	Filtrage des paquets selon des règles (adresse, port, sens). **Hôte** : sur chaque système ; **réseau/centralisé** : entre segments. Distinct de l'isolation fournie par le réseau virtuel.
Docker	Exécution d'applications dans des conteneurs partageant le noyau de l'hôte ; surface d'attaque propre au démon [8].

Notion	Définition retenue dans ce rapport
Journalisation	Enregistrement horodaté des événements ; la corrélation et l'investigation exigent des horloges synchronisées et des sources complètes.

Principe directeur. Ces catégories ne sont pas interchangeables : un IdP ne remplace pas un PAM, un SIEM ne remplace pas l'application des droits, et un pare-feu ne remplace pas le contrôle d'accès applicatif. Le choix final des outils dépendra des fonctions nécessaires, des contraintes de licence et des résultats de faisabilité.

2.3 Étude comparative des solutions

2.3.1 Fiches synthétiques

Active Directory Domain Services (AD DS) — annuaire et authentification de domaine Windows. Points forts : standard d'entreprise, DNS intégré. Limites : ne contrôle pas les privilèges sur Linux/Docker ; l'utilisation des comptes AD dans Teleport n'est pas automatique (cahier des charges). Licence Windows Server à vérifier (évaluation).

Keycloak — fournisseur d'identité (SSO, fédération LDAP/AD, MFA). Limite structurante : d'après la documentation de Teleport citée dans le cahier des charges [1], l'intégration SSO Keycloak–Teleport nécessite Teleport Enterprise ; Teleport Community Edition ne prend en charge que GitHub comme fournisseur SSO externe. **Cette intégration n'est donc pas acquise** dans l'architecture retenue.

Teleport Community Edition (candidate) — solution d'accès sécurisé à évaluer pour les ressources effectivement prises en charge. Les fonctions disponibles dépendent de la version et de l'édition. La documentation de licence indique des conditions d'éligibilité spécifiques depuis la version 16 [2] ; la conformité de l'usage prévu doit être vérifiée avant de retenir cette solution.

JumpServer — bastion/PAM open source (GPLv3) donnant accès à SSH, RDP, Kubernetes et bases via navigateur, avec audit de sessions [6]. Alternative crédible : interface Web native et intégration LDAP/AD annoncée ; empreinte probablement plus lourde (plusieurs composants), *à mesurer*.

HashiCorp Boundary (Community) — accès par identité aux ressources. D'après une source indépendante [7], l'édition communautaire est sous licence BSL 1.1 (source-available) et l'enregistrement de sessions est réservé aux offres payantes ; à confirmer sur la documentation éditeur.

Wazuh — plateforme de supervision : agents, manager, indexeur, tableau de bord [4]. Ne fait pas respecter les droits. Ports et transport dépendent de la version (voir section 4.5).

Docker Engine et Compose — exécution de conteneurs et description déclarative des services. Contraintes de sécurité : accès au démon, publication de ports et interaction avec le pare-feu [8, 9].

2.3.2 Tableau comparatif

Tableau 2.2: Solutions d'accès privilégié (comparaison par critère)

Critère	Teleport CE	JumpServer	Boundary CE
Fonction principale	Accès sécurisé aux infrastructures	Bastion / PAM	Accès par identité
Contrôle des privilèges	Oui (rôles, accès contrôlé)	Oui (permissions d'assets)	Oui (à confirmer)
Gestion des identités	Locale (CE) ; SSO limité à GitHub	Locale ; LDAP/AD annoncé	Via IdP

Tableau 2.2: Solutions d'accès privilégié (comparaison par critère)

Critère	Teleport CE	JumpServer	Boundary CE
Authentification / MFA	MFA selon configuration, à vérifier	MFA annoncé	Via IdP
Journalisation / audit	Audit, sessions prises en charge	Enregistrement et audit	Sessions : offres payantes [7]
Lien avec AD	Pas automatique	LDAP/AD annoncé	À étudier
Linux et Docker	Cible Linux ; Docker non géré en interne	Cible Linux	Cible Linux
Facilité en laboratoire	Bonne	Moyenne (*à mesurer*)	Moyenne
Limites / licence	< 100 employés, < 10 M$ [2]	GPLv3 ; édition entreprise payante	BSL 1.1

Tableau 2.3: Identité, supervision et conteneurs (catégories distinctes, non interchangeables)

Critère	AD DS	Keycloak	Wazuh	Docker / Compose
Fonction principale	Annuaire, DNS	IdP / SSO	SIEM/XDR	Conteneurs
Contrôle des privilèges	Non (côté Linux)	Non	Non	Non
Gestion des identités	Oui	Oui	Non	Non
Authentification / MFA	Kerberos ; MFA selon configuration	MFA, SSO	Accès console	Non
Journalisation / audit	Journaux Windows	Événements d'authentification	Collecte, corrélation	Journaux Docker
Lien avec AD	Natif	Fédération possible	Collecte d'événements	—
Linux et Docker	Hors périmètre	Application compatible	Agent Linux ; Docker à configurer	Natif
Facilité en laboratoire	Moyenne	Moyenne (ressources)	Déjà présent	Bonne
Limites / licence	Licence Windows	Intégration Teleport : Enterprise	Open source	Open source (versions à vérifier)

2.4 Justification du choix des composants

- **AD DS + DNS** : référentiel d'identités exigé par le cahier des charges (BF01). Rôle limité à l'annuaire et au DNS du domaine ; il n'est pas un fournisseur SSO de Teleport.
- **Teleport Community Edition** : candidate à évaluer pour les accès Linux, les rôles et l'audit. La compatibilité avec les ressources, la licence applicable et les fonctions requises restent à vérifier avant décision.
- **Wazuh** : présent en conteneurs sur le poste hôte ; la collecte des journaux du projet et les règles éventuelles restent à configurer et à tester.
- **Docker Engine + Compose** : option envisagée pour héberger un service de test si la charge mémoire et la configuration le permettent.
- **Keycloak** : conditionnel, pour la fédération AD ou une application compatible (BF13, T12) ; jamais présenté comme SSO de Teleport CE.
- **JumpServer, Boundary** : étudiés comme alternatives, non retenus à ce stade ; JumpServer constitue le repli si Teleport CE se révèle inadapté (décision à valider).

2.5 Synthèse de l'étude de l'existant

Lacune identifiée	Réponse proposée
Accès SSH direct et privilèges permanents	PAM (Teleport) avec rôles ; blocage réseau du SSH direct
Identités non centralisées	AD DS/DNS ; Keycloak éventuel
Surface Docker	Droits Docker distincts (BF06), exposition minimale des ports, filtrage `DOCKER-USER`
Journaux dispersés	Wazuh, horloges synchronisées, journaux pare-feu
Réseau à plat sans filtrage	Pare-feu hôtes (recommandé), pare-feu centralisé en option

Chapitre 3

Analyse des besoins et cahier des charges

3.1 Problématique détaillée

Un accès privilégié insuffisamment contrôlé expose à : l'escalade de privilèges, la modification non autorisée de configurations, l'accès aux données, la persistance d'un attaquant, et une impossibilité de reconstituer les faits. Deux contournements sont critiques : l'accès direct (SSH, base de données, API Docker) qui évite le PAM, et la supervision insuffisante qui empêche la détection.

3.2 Objectifs mesurables

Les cibles d'évaluation envisagées sont : vérifier les décisions RBAC sur la matrice définie ; tester le blocage des accès directs retenus ; vérifier la disponibilité des journaux et évaluer une règle de détection simple si les sources sont collectées ; contrôler les flux légitimes après filtrage. Les tests dépendant de composants non encore déployés seront reportés ou retirés du périmètre. Aucun taux de réussite n'est présumé ; les seuils seront confirmés avant les tests.

3.3 Acteurs et rôles

Profils logiques de test, associés ensuite aux mécanismes réellement configurés (rôles Teleport, groupes AD, comptes Linux, rôles PostgreSQL).

- **AI** Administrateur de l'infrastructure ; **OA** Opérateur applicatif ; **UL** Utilisateur à privilèges limités ;
- **AS** Analyste sécurité ; **AP** Administrateur de la solution PAM.

3.4 Besoins fonctionnels

ID	Description	Acteur	Priorité	Critère de validation
BF01	Annuaire centralisé des identités et groupes du domaine de laboratoire	AP, AI	Haute	Domaine opérationnel, comptes de test créés, DNS résolu
BF02	Autoriser/refuser l'accès aux ressources protégées selon les rôles PAM	AP, AI, OA, UL	Haute	Exactitude RBAC = 100 % sur la matrice (T02, T03)
BF03	Séparer au minimum administrateur, opérateur applicatif et utilisateur limité	AP	Haute	Matrice de permissions testée (T03, T04)
BF04	Accès contrôlé aux ressources prises en charge par le PAM	AI, OA	Haute	T02

ID	Description	Acteur	Priorité	Critère de validation
BF05	Bloquer les connexions directes non autorisées vers le serveur cible	AI, AS	Haute	T01, T11, T13
BF06	Réserver l'administration de Docker et de son socket aux acteurs autorisés	AI	Haute	T05
BF07	Isoler les services (non-root, capacités limitées, ports minimaux, secrets protégés)	AI	Moyenne	Revue du fichier Compose ; T09
BF08	Journaliser utilisateur, heure, ressource, origine, résultat quand disponibles	AS	Haute	Couverture de journalisation (T08, T10)
BF09	Centraliser les événements pertinents dans Wazuh	AS	Haute	Événements visibles dans Wazuh
BF10	Règles pour échecs répétés, accès interdit, modification sensible, activité inhabituelle	AS	Haute	T07 ; taux de détection, MTTD
BF11	Reconstituer une chronologie à partir des journaux	AS	Moyenne	T08, T10
BF12	Mesurer l'efficacité par scénarios et indicateurs	AI, AS	Haute	Indicateurs calculés sur résultats réels
BF13	Évaluer Keycloak et la fédération AD (optionnel)	AP	Basse	T12, si retenu et supporté
BF14	Filtrer le trafic par pare-feu hôtes et, si retenu, filtrage centralisé	AI	Haute	Règles documentées et actives ; T13–T16
BF15	N'autoriser que les communications nécessaires aux services et chemins d'administration	AI	Haute	Matrice des flux conforme aux règles ; T16, T18
BF16	Empêcher les connexions directes non autorisées, dont le SSH direct du scénario de contournement	AI, AS	Haute	T13 (et T01, T11)
BF17	Collecter les événements de pare-feu si la configuration le permet, et les intégrer à la supervision	AS	Moyenne	T17

3.5 Besoins non fonctionnels

ID	Description	Critère de validation
BNF01	Sécurité : moindre privilège, interfaces d'administration limitées, secrets protégés	Revue de configuration ; aucun secret dans le dépôt
BNF02	Isolation : réseau de laboratoire isolé, communications limitées au nécessaire	Réseau Host-only [13] + règles (T16)
BNF03	Traçabilité : horloges synchronisées, journaux horodatés	Écart d'horloge mesuré avant les tests
BNF04	Performance : fonctionnement sur environ 16 Go de RAM	Toutes les VM actives sans saturation mémoire (*à mesurer*)
BNF05	Maintenabilité : configurations documentées, reproductibles, versionnées	Dépôt de configurations expurgées
BNF06	Disponibilité du laboratoire : redémarrage indépendant, restauration par snapshots	Snapshot et restauration testés
BNF07	Évolutivité : ajout de rôles, services, scénarios	Ajout d'un rôle de test sans refonte
BNF08	Auditabilité : tests, résultats et limites documentés	Fiches de test complétées
BNF09	Compatibilité : versions et fonctions vérifiées avant chaque intégration	Tableau des versions
BNF10	Confidentialité : comptes et données de test uniquement	Revue des jeux de données
BNF11	Défense en profondeur : isolation, filtrage, contrôle d'accès, journalisation	Chaque couche testée séparément
BNF12	Minimisation de la surface d'attaque : aucun port ou service superflu exposé	T16

ID	Description	Critère de validation
BNF13	Maintenabilité des règles : règles de pare-feu documentées et justifiées	Chaque règle liée à une ligne de la matrice des flux
BNF14	Compatibilité avec les ressources : aucune VM supplémentaire dédiée au pare-feu	Inventaire des VM inchangé

3.6 Contraintes

Ressources limitées (environ 16 Go) ; fonctions dépendantes de l'édition (Teleport CE, licence [2]) ; limites d'intégration (pas de SSO Keycloak–Teleport CE) ; risque d'escalade par Docker ; disponibilité et qualité des journaux ; réseau isolé nécessaire ; dépendances et versions (Wazuh : ports différents selon les versions [4]) ; rôle final d'Ubuntu Server non fixé ; disponibilité de Kali à confirmer.

3.7 Périmètre et hors périmètre

Périmètre envisagé (à valider)	À valider / hors périmètre
AD DS/DNS ; évaluation PAM ; un service Linux de test ; Wazuh si collecte possible ; pare-feu hôtes ; scénarios sélectionnés parmi T01–T18	Keycloak (conditionnel) ; pare-feu centralisé sur Ubuntu (option A) ; JumpServer (repli) ; cloud public ; haute disponibilité ; SSO Keycloak–Teleport CE ; licence commerciale ; SOAR ; contrôle de chaque action métier dans les conteneurs

3.8 Critères d'acceptation

Les critères d'acceptation définitifs seront ajustés au périmètre validé avec l'encadrant. À minima, le rapport final devra distinguer les composants installés des composants seulement envisagés, documenter les règles et tests réellement réalisés, présenter les preuves disponibles, calculer les indicateurs uniquement lorsque les données existent et exposer les limites rencontrées. Les scénarios dépendant d'un composant non retenu ne seront pas présentés comme réussis.

Chapitre 4

Conception préliminaire de la solution

4.1 État de l'environnement et hypothèses de déploiement

Cette section décrit l'état au moment de la conception. L'environnement effectivement construit (trois VM Linux/Windows, Teleport, Docker, pare-feu) est décrit au chapitre 5.

À la date de rédaction, les seules machines de laboratoire confirmées pour ce projet sont une VM Windows Server destinée à AD DS/DNS et une VM Ubuntu Server. Wazuh est déjà exécuté en conteneurs Docker sur le poste hôte Windows. La disponibilité et la topologie définitive de Kali Linux pour les tests doivent être confirmées dans l'inventaire final. Aucun serveur Teleport séparé, serveur applicatif séparé ni pare-feu dédié n'est considéré comme déjà installé.

La suite du rapport distingue donc l'architecture logique cible des machines effectivement disponibles. Les rôles logiciels ne correspondent pas automatiquement à des VM distinctes. Le rôle final d'Ubuntu Server et l'emplacement d'exécution de Teleport restent à décider. Pour préserver la valeur du contrôle PAM, Teleport et la ressource protégée ne devraient pas partager la même frontière d'administration si cela peut être évité ; si la contrainte de ressources impose une colocalisation temporaire, cette limite devra être explicitement documentée et les résultats ne devront pas être présentés comme équivalents à une séparation en production.

Aucune VM supplémentaire ne sera créée uniquement pour le pare-feu. Le filtrage de base repose sur les pare-feu natifs des systèmes. Un pare-feu/routeur centralisé réutilisant Ubuntu ne sera envisagé qu'après validation d'une topologie à plusieurs réseaux et d'un rôle exclusif pour Ubuntu.

4.2 Architecture logique

La figure suivante représente les fonctions visées, et non un inventaire de VM déjà déployées. Les deux machines confirmées sont Windows Server (AD DS/DNS) et Ubuntu Server ; Wazuh est actuellement hébergé en conteneurs sur le poste Windows hôte. Les composants Teleport, Docker et les services applicatifs sont des rôles cibles dont l'affectation physique reste à valider.

Rôles. AD DS/DNS fournit l'annuaire et la résolution de noms du domaine de laboratoire. Teleport est la passerelle logique d'accès privilégié aux ressources qu'il prend en charge, mais son emplacement n'est pas encore fixé. Ubuntu Server est disponible, mais sa fonction (cible applicative, service PAM ou routeur/pare-feu) doit être décidée avant l'installation. Wazuh pourra servir à la collecte et à l'analyse des événements retenus ; sa présence sur le poste hôte ne signifie pas que les journaux du laboratoire y sont déjà envoyés. Le filtrage est assuré d'abord par les pare-feu des hôtes. Keycloak demeure optionnel et ne fait pas partie du chemin SSO de Teleport Community Edition.

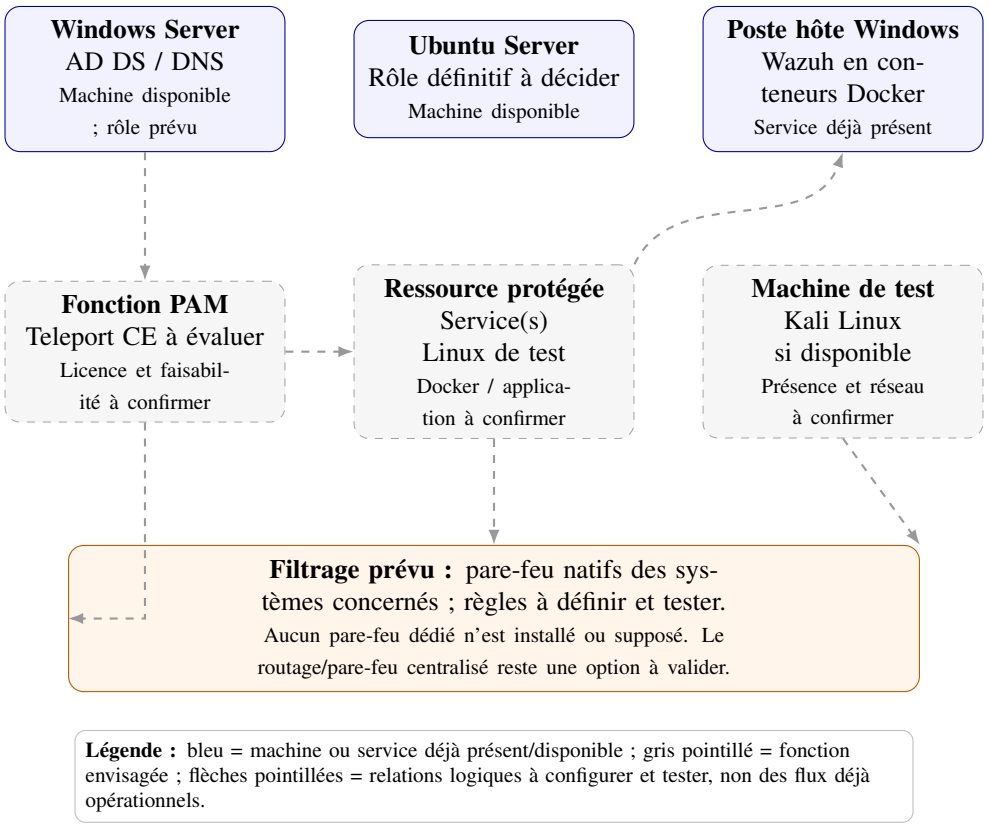


Figure 4.1: Architecture logique cible et distinction entre inventaire disponible et fonctions envisagées

4.3 Plan d'adressage

Mise à jour : le réseau VMnet1 et les adresses 192.168.70.10 (DC-01), .20 (GW01), .30 (TARGET01) et .1 (PC) sont désormais affectés et vérifiés (chapitre 5) ; le texte suivant correspond à la phase de conception. Le réseau VMware Host-only et les adresses IP n'étaient pas encore confirmés à cette phase. Le sous-réseau `192.168.70.0/24` est une hypothèse de travail uniquement ; il ne devra être utilisé qu'après vérification de l'absence de conflit avec le réseau local et les réseaux virtuels existants. Les adresses du contrôleur de domaine, d'Ubuntu, du poste hôte et de la machine de test seront attribuées après validation de la topologie ; les suffixes `.10`, `.20`, `.30` et `.40` présents dans certains scénarios initiaux ne sont pas des adresses actuellement affectées. Le réseau Host-only fournit une isolation vis-à-vis du réseau physique, mais ne filtre pas à lui seul les flux entre machines virtuelles [13].

4.4 Pare-feu et filtrage des flux réseau

4.4.1 Rôle dans la défense en profondeur

Le pare-feu contrôle l'*accessibilité réseau* ; le PAM contrôle l'*accès privilégié* aux ressources qu'il prend en charge. Aucun ne remplace l'autre : un SSH direct autorisé par le réseau contourne le PAM, et un PAM sans filtrage peut être contourné par le chemin réseau. La couche de filtrage complète l'isolation, le contrôle d'accès et la journalisation (BNF11).

4.4.2 Isolation, pare-feu hôte et pare-feu centralisé

	Host-only (VMware)	**Pare-feu hôte**	**Pare-feu centralisé**
Rôle	Isole le laboratoire du réseau physique [13]	Filtre le trafic entrant/sortant d'un système	Filtre le trafic entre segments
Granularité	Réseau entier	Par machine, par port, par source	Par segment ou par flux
Limite	Pas de politique de flux entre VM d'un même réseau	Gérée sur chaque machine ; modifiable par un administrateur local compromis	Point unique à protéger ; exige routage et interfaces multiples

Le Host-only n'est donc **pas** un pare-feu d'entreprise : il isole, il ne filtre pas les flux entre VM.

4.4.3 Étude des options

Option A — Réutiliser Ubuntu Server comme pare-feu/routeur. Ubuntu utilise Netfilter ; `nftables` est le moteur moderne et `ufw` un frontal simplifié [11]. Prérequis : deux interfaces au moins sur deux réseaux Host-only distincts (le Virtual Network Editor permet plusieurs réseaux Host-only [15]), activation du routage IPv4, routes ou passerelle sur chaque VM, et un rôle exclusif. **Non faisable tant que le rôle final et la topologie d'Ubuntu ne sont pas fixés.** Si Ubuntu est aussi la cible Docker, une machine compromise contrôlerait le filtre : combinaison déconseillée ; si Ubuntu est aussi le serveur Teleport, le point d'entrée et le routeur partagent le même risque : compromis à documenter.

Option B — Pare-feu natifs. Windows Defender Firewall sur Windows Server et `ufw`/`nftables` sur les machines Linux, avec Host-only pour l'isolation. Point d'attention : les ports publiés par Docker contournent les règles `INPUT` d'`ufw` ; il faut ne pas publier les ports inutiles, ou filtrer dans `DOCKER-USER` [9, 10].

Critère	**A : Ubuntu routeur**	**B : pare-feu natifs**
Sécurité	Point de contrôle entre segments ; point unique de défaillance	Filtrage par hôte ; réseau plat, pas de filtrage entre segments
Complexité	Élevée (2 interfaces, routage, routes)	Modérée (deux familles d'outils)
Ressources	Pas de VM ajoutée, mais Ubuntu mobilisé	Négligeables
Testabilité	Tests inter-segments clairs, journaux centralisés	Tests par hôte, journaux hétérogènes
Adéquation	Plus proche d'une architecture d'entreprise ; dépend du rôle d'Ubuntu	Faisable avec l'existant dès maintenant

Option de départ proposée. Utiliser les pare-feu natifs comme mesure de base, sans ajouter de VM, sous réserve de l'accord de l'encadrant. Cette option permet de filtrer les accès à chaque système et de documenter les règles, mais elle ne constitue pas un pare-feu réseau centralisé entre segments. Comme l'encadrant a demandé un pare-feu dans l'architecture d'entreprise, il faut lui faire valider explicitement si le filtrage hôte répond à cette exigence. Si un équipement centralisé est obligatoire, l'option A devra être étudiée après attribution d'un rôle exclusif à Ubuntu et mise en place de deux réseaux distincts ; elle ne doit pas être représentée comme déployée à ce stade.

4.4.4 Segmentation, moindre privilège et anti-contournement

- **Zones logiques** : identité (DC), accès (PAM), charge de travail (TARGET), supervision (Wazuh), test (Kali). Appliquées par règles d'hôtes (option B) ou par segments physiques (option A).
- **Moindre privilège réseau** : politique par défaut « refuser » en entrée ; ouvertures nominatives par source, destination et port ; sortie restreinte aux destinations nécessaires. Les ports Teleport, Wazuh

et AD sont à confirmer selon les versions, les rôles réellement installés et la configuration retenue ; les valeurs indicatives de la matrice ne sont pas des règles à appliquer sans vérification.

- **Contournement SSH** : le SSH direct vers serveur cible Linux est refusé aux sources non autorisées ; la connexion Teleport–cible reste fonctionnelle. Selon la variante, la cible n'ouvre que le port d'écoute Teleport depuis l'adresse du serveur PAM (connexion directe, port `3022` par défaut), ou n'ouvre aucun port entrant de gestion (l'agent établit un tunnel inverse sortant vers le Proxy) [3]. Un accès de secours (console de la VM) est à prévoir et documenter.
- **Docker et PostgreSQL** : API Docker jamais exposée en TCP ; PostgreSQL non publié sur l'hôte et joint seulement via un réseau Docker interne dédié ; Nginx seul point d'entrée applicatif.
- **Journalisation** : `ufw` peut activer la journalisation [12] ; `nftables` via la cible `log` avec préfixe ; journal des paquets rejetés de Windows Defender Firewall à activer (à vérifier). L'ingestion par Wazuh et le décodage sont **à valider** ; le volume de journaux doit être limité aux refus et aux flux de test.

Limites. Un pare-feu ne prévient pas l'escalade de privilèges d'un utilisateur déjà doté de permissions locales excessives et ne remplace pas les contrôles d'autorisation des applications ou de PostgreSQL.

4.5 Matrice des flux réseau (proposée)

Tableau 4.1: Matrice indicative des flux — hypothèses à confirmer avant toute configuration

Source	Destination	Protocole/port	Objet	Politique proposée	Validation
Poste d'admin autorisé (à désigner)	Service Teleport (emplacement à confirmer)	TCP 443 (routage TLS) ou 3080 [3] ; *à confirmer*	Point d'entrée Teleport	Autoriser depuis les sources d'admin désignées seulement	T02, T18
Service Teleport	serveur cible Linux (emplacement à confirmer)	Variante tunnel inverse : sortant de la cible vers le Proxy (443 ou 3024) ; variante connexion directe : TCP 3022 vers la cible [3] ; *à confirmer* selon la configuration retenue	Accès SSH géré par le PAM	Autoriser uniquement la variante retenue, avec l'adresse du serveur PAM comme seule source	T02, T13, T18
machine de test autorisée (Kali, disponibilité à confirmer)	serveur cible Linux (emplacement à confirmer)	TCP 22	Tentative de contournement du PAM	Refuser et journaliser (DROP ou REJECT : décision à valider)	T01, T11, T13
Conteneur application	Conteneur PostgreSQL	TCP 5432, réseau Docker interne	Accès base par l'application	Autoriser sur le réseau Docker interne dédié ; 5432 non publié sur l'hôte	T09, T14
Source non autorisée (Kali)	serveur cible Linux	TCP 5432	Accès direct à PostgreSQL	Refuser (port non publié + règle hôte)	T14, T16
Membres du domaine / composants	Windows Server (AD DS/DNS)	DNS 53, Kerberos 88, LDAP 389 et autres ports AD ; *à confirmer* (documentation Microsoft à vérifier)	Résolution DNS, authentification, jointure	Autoriser depuis les membres du domaine uniquement	T18
Hôte cible Linux (agent Wazuh si installé)	Manager Wazuh	TCP 1514 (événements) et 1515 (enrôlement) pour les agents 4.x ; 1517/TCP pour les agents 5.x [4, 5] ; *à confirmer* selon la version	Remontée des événements	Autoriser en sortie vers l'adresse du manager seulement	T17, T18
Hôte exécutant Teleport (agent Wazuh si installé)	Manager Wazuh	Mêmes ports, *à confirmer*	Journaux d'audit Teleport	Idem	T10, T18
Clients autorisés	Nginx (TARGET)	TCP 80/443 selon la configuration	Accès à l'application	Autoriser depuis les clients autorisés	T15
Toute source	TARGET : API Docker	TCP 2375/2376	Administration Docker	Refuser ; socket Unix local uniquement	T05, T16

Tableau 4.1: Matrice indicative des flux — hypothèses à confirmer avant toute configuration

Source	Destination	Protocole/port	Objet	Politique proposée	Validation
Toute source	TARGET : autres ports entrants	Tous, hors ports ouverts ci-dessus	Réduction de surface	Refuser par défaut	T16
Machines du laboratoire	Internet / autres réseaux	Tous	Contrôle du sortant	Refuser par défaut ; Host-only n'offre pas d'accès Internet par défaut [14] ; exceptions temporaires documentées	T16, T18

4.6 Matrice initiale des rôles et permissions (proposée)

Ressource	AI	OA	UL	AS	AP
Accès à la ressource cible via Teleport	Oui	Oui (compte limité)	Non	Non	Non
Élévation d'administration système	Oui	Non	Non	Non	Non
Administration Docker	Oui	Limité (à définir)	Non	Non	Non
Configuration Nginx protégée	Écriture	Rechargement (à définir)	Non	Non	Non
Administration PostgreSQL	Oui	Non (compte applicatif)	Non	Non	Non
Utilisation de l'application	Oui	Oui	Oui	—	—
Console Wazuh	Lecture	Non	Non	Oui	Non
Administration de Teleport	Non	Non	Non	Non	Oui

Le périmètre « Limité » de l'opérateur applicatif sur Docker est un point de risque : toute commande permettant de piloter Docker peut donner un accès équivalent à `root` [8]. Son mécanisme est à définir.

4.7 Analyse des menaces liées au filtrage

Menace	Mesure proposée	Preuve d'efficacité
Accès réseau non autorisé	Politique par défaut « refuser », ouvertures nominatives	Scan depuis Kali : ports fermés (T16)
SSH direct contournant le PAM	Refus du SSH direct hors chemin Teleport	Échec du SSH direct, succès via Teleport (T13)
Accès non autorisé à PostgreSQL	Port non publié, réseau Docker interne, règle hôte	Connexion refusée depuis Kali, application fonctionnelle (T14)
Exposition de l'administration Docker	Pas d'API TCP ; socket local ; droits Docker restreints	Port 2375/2376 fermé ; accès refusé (T05, T16)
Blocage accidentel de services légitimes	Règles testées et fiches de non-régression	AD/DNS, Teleport et Wazuh fonctionnels (T18)

Menace	Mesure proposée	Preuve d'efficacité
Règles mal configurées (dont contournement Docker du pare-feu)	Revue de règles, `DOCKER-USER` [9], snapshot avant modification	Comparaison matrice des flux et règles actives
Journaux de pare-feu absents ou incomplets	Activation de la journalisation, test d'ingestion	Événement généré visible dans Wazuh, ou limite documentée (T17)

4.8 Stratégie de collecte des journaux

Sources : système Linux (agent Wazuh sur l'hôte), authentification, audit Teleport, événements Docker configurés, Nginx et applicatifs, événements AD pertinents, journaux de pare-feu. Les règles de détection sont élaborées à partir des journaux réellement collectés et ne sont validées qu'après test. Les horloges sont synchronisées (source de temps unique, à définir) avant toute mesure.

4.9 Plan de tests

Les tests ci-dessous constituent un catalogue de scénarios candidats, pas un engagement à les exécuter tous. Les scénarios retenus seront adaptés à la topologie approuvée et aux composants effectivement installés. Avant chaque test, vérifier l'autorisation, les comptes de test, la possibilité de restauration et les préconditions propres au scénario. Les résultats observés sont à renseigner après exécution ; une précondition absente entraîne le report ou le retrait du test, et non une réussite présumée.

4.9.1 Tests T01 à T12 (synthèse)

ID	Scénario	Résultat attendu	Preuves	Observé
T01	SSH direct non autorisé	Refus, événement exploitable	Sortie client, journaux	*à mesurer*
T02	Accès via le chemin PAM autorisé	Connexion réussie selon le rôle	Audit Teleport	Réussi (A2, ch. 5)
T03	Action privilégiée par utilisateur sans rôle	Refus	Journaux sudo/Teleport	Réussi (A5, ch. 5)
T04	Opérateur gère un service autorisé	Action permise dans le périmètre	Journaux	*à mesurer*
T05	Administration Docker non autorisée	Refus	Journaux Docker/système	Réussi (A6, ch. 5)
T06	Modification non autorisée de la configuration Nginx	Blocage et/ou événement détectable	Journaux, alerte	*à mesurer*
T07	Échecs d'authentification répétés	Événements collectés, détection évaluée	Alertes Wazuh, horodatages	*à mesurer*
T08	Activité administrative autorisée	Journaux exploitables pour l'investigation	Chronologie	*à mesurer*
T09	Action sensible PostgreSQL via compte applicatif	Refus selon privilèges	Journaux PostgreSQL	*à mesurer*
T10	Corrélation PAM, système, applicatif	Chronologie reconstituable si données disponibles	Export corrélé	*à mesurer*
T11	Contournement du chemin PAM	Bloqué, ou faiblesse identifiée et corrigée	Rapport de test	*à mesurer*
T12	Keycloak (si retenu et supporté)	Évaluation de la fédération AD	Notes de test	*à mesurer*

4.9.2 Tests de pare-feu T13 à T18

Les fiches ci-dessous restent le protocole prévu. Les tests F1 à F9 du chapitre 5 en constituent une exécution partielle, depuis GW01 et le PC et non depuis Kali ; aucune fiche n'est donc considérée comme réussie à ce stade.

T13 — SSH direct non autorisé	
Objectif	Vérifier que le SSH direct interdit est bloqué et que l'accès Teleport autorisé reste fonctionnel
Préconditions	Règles hôte actives sur la cible retenue ; Teleport opérationnel et son emplacement confirmé ; compte de test valide ; source Kali hors liste d'autorisation
Procédure	1) Depuis Kali, tenter un SSH vers `<adresse_IP_cible>:22`. 2) Depuis le poste autorisé, se connecter via Teleport. 3) Relever les journaux
Résultat attendu	1) refus ou délai dépassé, avec événement de pare-feu ; 2) connexion réussie
Preuves à collecter	Sorties de commande, journaux de pare-feu et Teleport, horodatages
Résultat observé	*à mesurer* (test non exécuté)

T14 — Isolation de PostgreSQL	
Objectif	Vérifier que PostgreSQL n'est joignable que par l'application
Préconditions	Si les services Docker sont retenus : port 5432 non publié ; réseau Docker interne dédié
Procédure	1) Depuis Kali, test de connexion vers `<adresse_IP_cible>:5432`. 2) Depuis l'application, requête de test légitime
Résultat attendu	1) échec de connexion ; 2) requête réussie
Preuves à collecter	Sorties de test, journaux applicatifs, configuration Compose expurgée
Résultat observé	*à mesurer* (test non exécuté)

T15 — Exposition du service Web	
Objectif	Vérifier que seuls les clients prévus atteignent Nginx
Préconditions	Nginx exposé sur les ports retenus ; liste des clients autorisés définie
Procédure	1) Accès depuis un client autorisé. 2) Accès depuis un client non autorisé
Résultat attendu	1) réponse HTTP ; 2) refus ou absence de réponse
Preuves à collecter	Réponses HTTP, journaux Nginx et pare-feu
Résultat observé	*à mesurer* (test non exécuté)

T16 — Ports entrants inutiles	
Objectif	Vérifier que les ports non nécessaires sont fermés ou filtrés
Préconditions	Matrice des flux figée ; règles appliquées
Procédure	Scan de ports des hôtes effectivement déployés depuis la machine de test autorisée ; comparaison avec la matrice
Résultat attendu	Seuls les ports de la matrice répondent
Preuves à collecter	Résultats du scan, règles actives exportées
Résultat observé	*à mesurer* (test non exécuté)

T17 — Journalisation du pare-feu	
Objectif	Vérifier qu'un refus ou une autorisation contrôlée est journalisé et visible dans Wazuh
Préconditions	Journalisation activée ; collecte Wazuh configurée (à valider)
Procédure	Générer une connexion refusée contrôlée ; chercher l'événement localement puis dans Wazuh
Résultat attendu	Événement présent localement ; présent dans Wazuh si configuré
Preuves à collecter	Extrait de journal, alerte ou événement Wazuh, horodatages
Résultat observé	*à mesurer* (test non exécuté)

T18 — Régression du trafic légitime	
Objectif	Vérifier que les règles ne bloquent pas AD/DNS, Teleport ni Wazuh
Préconditions	Topologie et composants retenus démarrés ; règles de pare-feu appliquées
Procédure	Résolution DNS ; authentification de domaine ; connexion Teleport ; remontée d'événements Wazuh
Résultat attendu	Tous les flux essentiels fonctionnent
Preuves à collecter	Sorties de test, journaux de chaque composant
Résultat observé	*à mesurer* (test non exécuté)

4.10 Indicateurs prévus

Formules et méthode uniquement ; aucune valeur n'est établie.

- Exactitude RBAC = décisions conformes à la matrice / total des tests d'autorisation $\times$ 100.
- Taux de blocage = tentatives non autorisées bloquées / tentatives non autorisées testées $\times$ 100.
- Couverture de journalisation = événements attendus journalisés / événements attendus testés $\times$ 100.
- Taux de détection = événements détectés / événements détectables $\times$ 100.
- MTTD = horodatage de détection $-$ horodatage de l'événement ; MTTA = horodatage de prise en charge $-$ horodatage de détection.
- Préservation des flux légitimes = flux essentiels fonctionnels après filtrage / flux essentiels testés $\times$ 100 (T18).

Les horloges doivent être synchronisées, les événements de référence définis avant les tests, et les faux positifs et limites de mesure documentés.

Chapitre 5

Mise en œuvre et résultats observés

5.1 Statut de ce chapitre et méthode

Ce chapitre décrit ce qui a **effectivement été réalisé et observé** dans le laboratoire entre le 12 et le 16 octobre 2026. Seules les sorties de commandes réellement obtenues figurent dans les tableaux « Observé ». Tout ce qui n'a pas été exécuté est regroupé à la section 5.12 et n'est **pas** présenté comme réussi. Les heures du journal d'audit Teleport sont en UTC ; l'heure locale (Tunis) est UTC+1. Aucun secret (mot de passe, jeton, clé privée) n'est consigné dans ce rapport.

5.2 Environnement réalisé

5.2.1 Machines et adressage

Le réseau est un réseau VMware *Host-only* (VMnet1), sous-réseau `192.168.70.0/24`, DHCP VMware désactivé. Le sous-réseau, qui n'était qu'une hypothèse de travail au chapitre 4, est désormais affecté et vérifié.

Tableau 5.1: Machines du laboratoire telles que construites

Machine	Rôle	Adresse	Système / version	Preuve
PAM-DC01	AD DS et DNS, domaine `pam.lab` (NetBIOS `PAM`)	192.168.70.10 (statique)	Windows Server 2022 Standard (évaluation)	PowerShell : services NTDS, DNS, Kdc, W32Time actifs
PAM-GW01	Teleport Community Edition (Auth + Proxy), passerelle PAM	192.168.70.20 (+ NAT temporaire)	Ubuntu 24.04.4 LTS, Teleport 18.11.3, 1,8 Gio de RAM	`teleport version`, réponse HTTPS sur 443
PAM-TARGET01	Hôte Linux protégé, services Docker	192.168.70.30 (+ NAT temporaire)	Ubuntu 24.04, Docker 29.1.3, Compose 2.40.3	`docker compose ps`, `ss -tlnp`
PC hôte	Client autorisé (`tsh` 18.11.3) ; futur hôte Wazuh	192.168.70.1 (VMnet1)	Windows 11	`Get-NetIPAddress`, ping 4/4
Kali Linux	Client non autorisé prévu	non confirmée	non confirmé	disponibilité à confirmer

5.2.2 Architecture réalisée

La figure 5.1 représente les flux effectivement mis en place et testés. Contrairement à la figure 4.1, toutes les machines représentées existent ; Wazuh et Kali ne sont pas représentés car ils ne sont pas encore intégrés.

Deux autorités de certification coexistent : une autorité de laboratoire créée avec `openssl` pour le certificat TLS du Proxy (`pam-gw01.pam.lab`, SAN DNS et IP), et l'autorité interne de Teleport pour les certificats

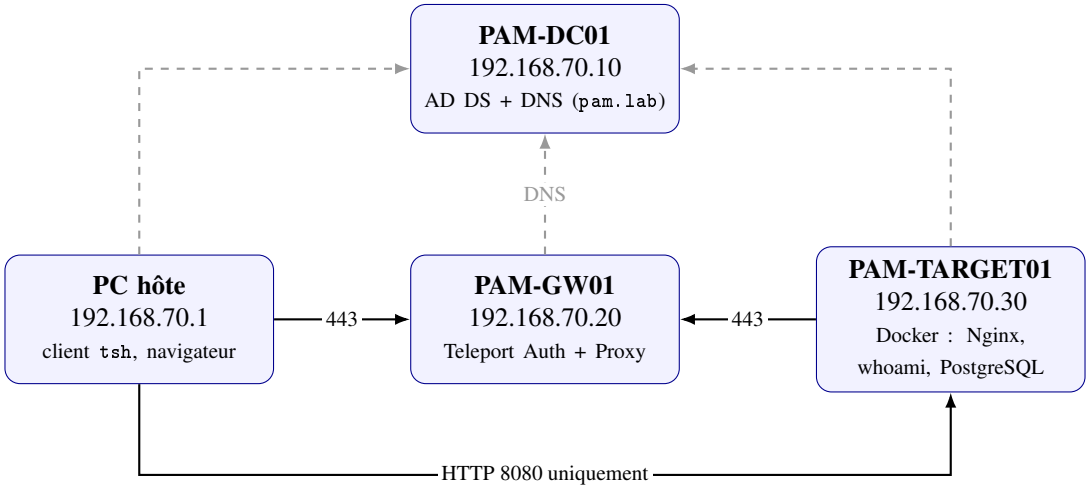


Figure 5.1: Architecture réalisée. Flèches pleines : flux autorisés et testés ; pointillés : résolution DNS. L'agent de TARGET01 ouvre lui-même le tunnel *sortant* vers le Proxy ; aucun port SSH entrant n'est nécessaire sur la cible.

d'utilisateurs et d'hôtes. Le certificat du Proxy est reconnu sans option `-k` une fois l'autorité de laboratoire ajoutée aux magasins de confiance.

5.3 Active Directory et DNS

Le contrôleur de domaine PAM-DC01 héberge le domaine `pam.lab` (niveau fonctionnel Windows 2016). L'inspection en lecture seule a confirmé le rôle de contrôleur de domaine (`DomainRole` 5), les services NTDS, DNS, Kdc et W32Time en fonctionnement et le service DHCP désactivé. Un enregistrement DNS A `pam-gw01.pam.lab` → `192.168.70.20` a été ajouté.

Rôle exact d'AD dans cette réalisation. Active Directory fournit le domaine et la résolution de noms. Les machines Linux ne sont *pas* jointes au domaine et les utilisateurs Teleport sont des comptes locaux : Teleport Community Edition ne propose comme SSO externe que GitHub, l'authentification OIDC, SAML ou Active Directory relevant des éditions Enterprise (documentation consultée le 14 octobre 2026 ; URL exacte de la matrice des fonctions à ajouter à la bibliographie *à confirmer*). Toute correspondance entre groupes AD et rôles Teleport serait manuelle et ne constituerait pas une intégration.

Dépendance constatée. L'agent de TARGET01 se connecte au Proxy par son nom. Après un démarrage à froid, `pam-target01` est resté absent de `tctl nodes ls` tant que DC-01 (DNS) n'était pas démarré, puis s'est reconnecté. Le DNS d'AD est donc une dépendance réelle du chemin PAM.

5.4 Déploiement de Teleport

Licence. Depuis la version 16, l'édition Community est gratuite pour les particuliers et les entreprises de moins de 100 salariés et de moins de 10 M$ de chiffre d'affaires [2] ; un laboratoire étudiant entre dans ce cadre (lecture de l'équipe, non avis juridique). Les demandes d'accès à la demande (*just-in-time*) ne sont disponibles qu'en ligne de commande dans cette édition.

Installation sur PAM-GW01.

1. Installation de Teleport 18.11.3 depuis le dépôt apt officiel au moyen du script du fournisseur (somme SHA-256 du script vérifiée).
2. Création de l'autorité de laboratoire et du certificat serveur ; `openssl verify` affiche `OK`.

3. `teleport configure` avec ce certificat, démarrage du service, réponse HTTPS sans `-k` ; authentification locale avec second facteur `otp`.

Enrôlement de PAM-TARGET01. Le nœud est enregistré sous le nom `pam-target01` avec les étiquettes `env=lab` et `role=docker-host`, au moyen d'un jeton valable 15 minutes. La connexion est un tunnel inverse sortant de la cible vers le Proxy.

Client. `tsh` 18.11.3 a été installé sur le PC ; la somme SHA-256 de l'archive correspond à la valeur publiée par l'éditeur.

5.5 Services Docker sur PAM-TARGET01

Trois conteneurs sont décrits par un projet Compose : Nginx, `traefik/whoami` (application de test) et `postgres:16`. Nginx est publié sur `192.168.70.30:8080` uniquement ; PostgreSQL n'est pas publié, et le réseau Compose `internal` sépare les composants. L'utilisateur d'administration n'a pas été ajouté au groupe `docker`.

Observations : les trois services sont `Up` ; `curl http://192.168.70.30:8080` renvoie la réponse de `whoami` à travers Nginx ; `ss -tlnp` ne montre que le port 8080 (processus `docker-proxy`) et aucun écouteur sur 5432. Le conteneur applicatif `whoami` n'interroge pas PostgreSQL : l'accessibilité de la base est donc testée au niveau réseau et avec `psql` dans le conteneur, et non par une requête applicative.

5.6 Rôles et utilisateurs implémentés

Quatre rôles Teleport ont été créés, avec un utilisateur par rôle, tous protégés par un mot de passe et un second facteur TOTP. Sur PAM-TARGET01, deux comptes Linux ont été créés : `sysadmin` (sudo sans mot de passe, connexion par mot de passe impossible) et `appop` (aucun sudo, hors du groupe `docker`). Teleport ne crée pas d'autorisation Linux : il limite *quel compte Linux* chaque rôle peut utiliser, et ce sont les permissions Linux qui produisent les refus `sudo` et `docker`.

Tableau 5.2: Rôles implémentés : ce que chacun peut et ne peut pas faire (résultats observés)

Rôle	Utilisateur	Compte Linux	Validité	Peut	Ne peut pas
`infra-admin` (profil AI)	`u-infra`	`sysadmin`	8 h	Ouvrir une session SSH via Teleport sur `pam-target01` ; exécuter des commandes avec `sudo` sans mot de passe, dont `docker ps`	Administrer Teleport ; se connecter hors du chemin Teleport
`app-operator` (profil OA)	`u-appop`	`appop`	2 h	Ouvrir une session SSH comme `appop` ; exécuter des commandes non privilégiées (`whoami`)	Utiliser `sudo` (refusé) ; utiliser `docker` (refusé) ; se connecter comme `sysadmin` (refusé par Teleport)
`limited-user` (profil UL)	`u-limited`	aucun	2 h	S'authentifier (mot de passe + OTP)	Ouvrir une session SSH sur toute ressource, quel que soit le compte (refusé par Teleport)
`pam-admin` (profil AP)	`pam-admin`	aucun	—	Administrer Teleport (rôles `editor` et `auditor`), consulter le journal d'audit et les enregistrements	Ouvrir une session SSH : aucune ressource ne lui est visible

Le profil analyste sécurité (AS) de la matrice du chapitre 4 n'est pas encore implémenté : il dépend de Wazuh. En attendant, le rôle `auditor` de `pam-admin` permet de lire l'audit Teleport. Les rôles portent la contrainte d'étiquette `env: lab`, ce qui limite leur portée aux ressources du laboratoire. Le compte

`sysadmin` dispose de privilèges root permanents sur la cible : le contrôle repose ici sur l'attribution du rôle, la durée de vie du certificat et l'audit (voir limites).

5.7 Tests d'autorisation observés

Tableau 5.3: Résultats observés des tests d'autorisation (14 octobre 2026)

N°	Acteur et action	Attendu	Observé	Résultat
A1	`u-infra` se connecte (mot de passe + OTP)	Succès, rôle `infra-admin`	`Logged in as u-infra, Roles: infra-admin, Logins: sysadmin`, valide 7 h 59	Réussi
A2	`u-infra : tsh ssh sysadmin@pam-target01` avec `whoami; hostname; sudo -n docker ps`	Autorisé	`sysadmin`, `pam-target01`, trois conteneurs listés	Réussi (T02)
A3	`u-appop` se connecte	Succès, rôle `app-operator`	Connexion réussie, valide 1 h 59	Réussi
A4	`u-appop` : `whoami` sur la cible	Autorisé	`appop`	Réussi
A5	`u-appop` : `sudo -n true`	Refusé	`sudo: a password is required`	Réussi (T03)
A6	`u-appop` : `docker ps`	Refusé	`permission denied` sur `docker.sock`	Réussi (T05)
A7	`u-appop : tsh ssh sysadmin@pam-target01`	Refusé par Teleport	`access denied to sysadmin connecting to pam-target01`	Réussi
A8	`u-limited` se connecte puis `tsh ssh appop@pam-target01`	Connexion réussie, SSH refusé	Connexion réussie, liste de comptes vide ; `access denied to appop connecting to pam-target01`	Réussi

Les huit vérifications ont donné le résultat attendu. Il s'agit d'un sous-ensemble provisoire : l'indicateur d'exactitude RBAC du chapitre 4 sera calculé sur la matrice finale de tests, et non sur ces huit lignes. Les refus A5 et A6 proviennent des permissions Linux ; l'apport de Teleport est de restreindre le compte utilisable (A7, A8).

5.8 Preuves d'audit

Le journal d'audit de Teleport (heures UTC) contient, entre autres :

- 10:57:46 `Local Login Failed [missing second factor]` pour `u-infra` (code OTP omis par erreur) : un échec d'authentification est bien journalisé ;
- 10:59:52, 11:00:03 et 11:00:05 : début de session, exécution de commande et fin de session de `u-infra` sur `pam-target01` ;
- 11:01:28 `Command Execution Failed [exit status 1]` pour `u-appop` (tentative `sudo/docker`) ;
- 11:02:02 `Auth Attempt Failed : u-appop`, compte « sysadmin » absent des comptes valides `["appop"]` ;
- 11:02:59 `Auth Attempt Failed` : `u-limited`, compte « appop » absent des comptes valides ;
- 11:04:21 à 11:04:51 : session interactive de `u-infra` (17 s), avec événement `Session Uploaded`.

L'enregistrement de session d'identifiant `bab664dd-5180-4704-bee2-705bad45eec8` apparaît à la fois dans l'audit et dans l'enregistrement, où les commandes `whoami` et `sudo docker ps` sont visibles. Les événements de mise en place (création d'utilisateurs, jetons, ajout d'appareils MFA, émission de certificats) sont également journalisés. L'heure de l'enregistrement (12:04 locale) correspond à l'heure d'audit (11:04 UTC) : GW01 et le PC sont cohérents.

5.9 Pare-feu : règles appliquées et tests

Les règles ont été appliquées le 16 octobre 2026, avec une minuterie de retour arrière de 15 minutes (`systemd-run`) comme filet de sécurité, annulée après validation. Elles mettent en œuvre l'option B du chapitre 4 (pare-feu natifs, sans machine supplémentaire).

5.9.1 Règles

PAM-TARGET01. `ufw` actif, politique « refuser » en entrée et « autoriser » en sortie, *aucune* règle d'autorisation SSH. Comme les ports publiés par Docker contournent les règles `INPUT` d'`ufw` [9], la chaîne `DOCKER-USER` contient : (1) `RETURN` pour TCP depuis 192.168.70.1 vers le port 8080 sur `ens33` ; (2) `DROP` pour le reste du trafic entrant sur `ens33` ; (3) `RETURN`. Ces règles sont reconstruites au démarrage par le service `docker-user-fw.service` (installé et activé).

PAM-GW01. `ufw` avec politique « refuser » en entrée ; autorisation de 443/tcp depuis 192.168.70.1 (PC) et 192.168.70.30 (TARGET01) ; autorisation de 22/tcp depuis 192.168.70.1 seulement.

5.9.2 Résultats

Tableau 5.4: Tests de filtrage avant/après (16 octobre 2026)

N°	Test	Avant	Après	Résultat
F1	GW01 → TARGET01:22 (connexion TCP)	ouvert	fermé/filtré	Réussi
F2	GW01 → TARGET01:8080	ouvert	fermé/filtré	Réussi
F3	GW01 → TARGET01:5432	fermé/filtré	fermé/filtré	Réussi (port jamais publié)
F4	PC → `http://192.168.70.30:8080`	réponse	réponse	Réussi (source autorisée)
F5	PC → nouvelle connexion SSH vers 192.168.70.30:22	non exécuté	`Connection timed out`	Réussi
F6	PC → `tsh ssh sysadmin@pam-target01 whoami`, SSH direct bloqué	fonctionne	`sysadmin`	Réussi (chemin PAM intact)
F7	TARGET01 → GW01:443 et :22 après pare-feu de GW01	non exécuté	443 ouvert, 22 fermé/filtré	Réussi
F8	Redémarrage de l'agent de TARGET01 puis `tctl nodes ls`	non exécuté	`pam-target01` listé	Réussi
F9	PC → `tsh ssh` à travers le pare-feu de GW01 (nouvelle session sur 443)	non exécuté	`sysadmin`	Réussi

Ces résultats illustrent la complémentarité décrite au chapitre 4 : le SSH direct vers la cible est refusé aux nouvelles connexions (F5) alors que l'accès par le PAM fonctionne toujours (F6, F9), parce que le tunnel est initié par la cible vers le Proxy et que la règle de GW01 autorise ce flux entrant sur 443 (F7, F8). Les tests F1 à F9 correspondent à une exécution **partielle** des tests T13, T14 et T15 : ils ont été menés depuis GW01 et le PC, non depuis Kali.

5.9.3 Observations à signaler

- Une session SSH du PC déjà ouverte avant l'application des règles est restée active : le pare-feu est à états, les règles ne s'appliquent qu'aux nouvelles connexions.
- Une première mesure « avant » était invalide (TARGET01 éteinte) et a été refaite ; seules les valeurs valides figurent dans le tableau.

- GW01 accepte toujours le SSH depuis le PC : c'est un chemin d'administration hors Teleport, conservé pour la mise au point et à supprimer avant les tests finaux s'il n'est plus nécessaire.
- Le DNS vers DC-01 doit rester autorisé (dépendance de l'agent, section précédente).

5.10 Difficultés rencontrées et corrections

- L'adaptateur VMnet1 de l'hôte avait une adresse 169.254.x.x : adresse statique 192.168.70.1/24 configurée. Les premiers pings ont échoué tant que l'adresse était à l'état provisoire ; le ping de GW01 vers l'hôte a nécessité une règle entrante ICMP limitée au sous-réseau du laboratoire et à l'adaptateur VMnet1.
- L'adaptateur NAT de GW01 a exigé son propre fichier netplan (`ens37`).
- `teleport configure` a d'abord échoué car les fichiers de certificat étaient dans le dossier personnel et non dans `/var/lib/teleport` ; le service redémarrait en boucle jusqu'au déplacement des fichiers et à la régénération de la configuration.
- Un délai de résolution DNS de `pam-gw01.pam.lab` a été observé sur TARGET01 au démarrage, résolu au nouvel essai (connexion de l'agent 13 s plus tard).
- La création des utilisateurs Linux a d'abord été lancée sur GW01 par erreur ; elle a été annulée sur GW01 puis refaite sur TARGET01.
- Un code OTP a été soumis vide (`missing second factor`) ; la connexion a réussi à l'essai suivant.

5.11 Limites et compromis assumés

- AD ne fournit que le DNS et le domaine ; les VM Linux ne sont pas jointes au domaine et les utilisateurs Teleport sont locaux (limite de l'édition Community).
- GW01 (Teleport) et TARGET01 (ressource protégée) sont deux VM distinctes, conformément à la recommandation du chapitre 4 ; la clé privée de l'autorité de laboratoire réside sur GW01 par commodité.
- `sysadmin` dispose de privilèges root permanents ; la maîtrise repose sur le rôle, la durée du certificat et l'audit.
- L'application `whoami` ne sollicite pas PostgreSQL.
- Les paquets Docker proviennent des dépôts Ubuntu, plus anciens que ceux de Docker.
- L'autorité de laboratoire est installée dans le magasin utilisateur du PC ; elle sera retirée à la fin du projet.
- GW01 et TARGET01 possèdent encore un adaptateur NAT temporaire (accès Internet) à supprimer ou bloquer avant les tests de pare-feu finaux.

5.12 Travaux restants

Les éléments suivants n'ont **pas** été exécutés et ne sont pas présentés comme réussis.

- Persistance du pare-feu après redémarrage de TARGET01 ; Windows Defender Firewall sur DC-01 et sur le PC ; filtrage sortant ; journalisation du pare-feu (T17) ; régression complète (T18).
- Machine Kali : disponibilité non confirmée ; scan de ports (T16) et tentatives de contournement non réalisés ; test PostgreSQL (T14) depuis une machine non autorisée non réalisé.

- Wazuh : Docker Desktop n'était pas démarré lors de la vérification ; aucun agent installé, aucune remontée de journaux, donc ni détection (T07) ni corrélation (T10) ; profil AS non implémenté.
- Révocation et expiration des accès (à vérifier d'abord dans la documentation Teleport).
- Examen de certains détails d'audit (texte des commandes, adresse source, quatre événements `Certificate Issued` de `u-limited` à 11:00:27 UTC).
- Synchronisation d'horloge de TARGET01 et de DC-01 non vérifiée.
- Suppression des adaptateurs NAT temporaires ; calcul des indicateurs finaux (aucune valeur finale n'est établie à ce stade).

Bibliographie et webographie

Sources consultées le 12 octobre 2026. Celles marquées † sont à vérifier avant le rendu final (non ouvertes pendant la rédaction ou version de documentation à confirmer).

Bibliography

[1] Teleport, « Keycloak SSO », documentation (URL fournie dans le cahier des charges) : https://goteleport.com/docs/zero-trust-access/sso/integrate-idp/keycloak/ †.

[2] Teleport, « Teleport Community Edition will adopt a commercial license starting with version 16 » : https://goteleport.com/blog/teleport-community-license.

[3] Teleport, « Networking Reference » : https://goteleport.com/docs/reference/deployment/networking/.

[4] Wazuh, « Architecture » (documentation de la branche 5.0, candidate au moment de la consultation) : https://documentation.wazuh.com/5.0-rc/getting-started/architecture.html † ; version déployée à confirmer.

[5] Wazuh, « Agent enrollment requirements » : https://documentation.wazuh.com/current/user-manual/agent/agent-enrollment/requirements.html.

[6] JumpServer, dépôt officiel : https://github.com/jumpserver/jumpserver.

[7] Start with Identity, « Top 7 Open-Source PAM Solutions » (source indépendante) : https://startwithidentity.com/articles/top-7-open-source-pam-solutions/ †.

[8] Docker, « Docker Engine security » : https://docs.docker.com/engine/security/.

[9] Docker, « Packet filtering and firewalls » : https://docs.docker.com/network/packet-filtering-firewalls/.

[10] Baeldung, « Docker published ports ignoring ufw rules » (source indépendante) : https://www.baeldung.com/linux/docker-container-published-port-ignoring-ufw-rules.

[11] Ubuntu, « Firewall » : https://documentation.ubuntu.com/security/security-features/network/firewall/.

[12] Ubuntu Wiki, « UncomplicatedFirewall » : https://wiki.ubuntu.com/UncomplicatedFirewall.

[13] Broadcom, « Understanding networking types in hosted products » : https://knowledge.broadcom.com/external/article/309842/understanding-networking-types-in-hosted.html.

[14] VMware, « Configuring Host-Only Networking » (Workstation Pro 17) : https://docs.vmware.com/en/VMware-Workstation-Pro/17/com.vmware.ws.using.doc/GUID-93BDF7F1-D2E4-42CE-80EA-4E305337D2FC.html †.

[15] VMware, « Add a Host-Only Virtual Network » (Workstation Pro 17) : https://docs.vmware.com/en/VMware-Workstation-Pro/17/com.vmware.ws.using.doc/GUID-E08995A9-7DE6-4D92-8C6F-4F737C3A8AB3.html †.

Vérifications bibliographiques avant remise : confirmer les pages et versions effectivement consultées, en particulier les pages Teleport, Wazuh et VMware marquées d'un symbole dans les brouillons antérieurs. Ajouter la documentation Microsoft officielle sur les ports AD DS/DNS et Windows Defender Firewall, ainsi que la documentation Keycloak et la référence NIST SP 800-92 si ces éléments sont effectivement utilisés. Ne conserver dans la bibliographie finale que les sources consultées et citées dans le texte.